

永恒之蓝（MS17-010）漏洞深度研究报告

SMBv1 协议栈技术细节与攻击面

SMBv1协议常运行在NetBIOS over TCP (NBT) 之上（通常在445/139端口），并分为固定头部、可变参数和数据块三部分^{1 2}。在OSI模型中，SMB协议的传输层多采用NBT (NetBIOS over TCP/IP)²，旧版兼容模式下也可直接在TCP上直连。SMB会话通过Negotiate、Session Setup、Tree Connect等报文建立，并支持“匿名会话”（如IPC\$共享）^{3 4}。攻击面上，SMB提供大量命令，其中TRANSACTION2/NT_TRANSACTION等可用来传输大块数据。特别地，SMB_COM_NT_TRANSACTION命令的TotalDataCount字段为32位（ULONG），支持传输超过0xFFFF字节的数据⁵。永恒之蓝正是利用了SMB_COM_NT_TRANSACTION与SMB_COM_TRANSACTION2_SECONDARY组合发送超长数据包的特性：首先发送一个大于0xFFFF长度的SMB_COM_NT_TRANSACTION请求，然后通过一系列SMB_COM_TRANSACTION2_SECONDARY分包组成一个总长为0x10000的交易包⁵。这一机制使攻击者能够绕过TRANSACTION2原本的长度限制，从而触发后续漏洞。总之，SMBv1协议栈（以NBT为载体）的会话控制和数据分片机制，为漏洞利用提供了通道；尤其是无须身份验证就能访问IPC\$的旧版Windows环境，为永恒之蓝利用奠定了基础^{3 2}。

MS17-010 漏洞技术解析

MS17-010的核心漏洞出现在srv.sys驱动的SrvOs2FeaToNt函数中。该函数负责将OS/2风格的文件扩展属性（FEA）列表转换为NT风格格式。漏洞在于SrvOs2FeaListSizeToNt计算长度时的类型转换错误：初始大小以DWORD表示，但后续更新时仅以WORD拷贝回去，若原始长度超过0xFFFF，计算结果就会被截断或增大^{6 7}。换言之，当攻击者提交一个长度≥0x10000的FEA列表时，转换函数会返回一个异常过大的目标长度。紧接着SrvOs2FeaToNt使用这个错误长度执行内存拷贝，导致目标缓冲区溢出^{8 7}。研究分析表明，正常情况下被填充的缓冲区位于srv.sys的SMB缓冲池中；但溢出后，多余的数据越界写入了相邻的srvnet.sys对象缓冲区⁸。

在srvnet对象中，关键的两个字段被覆盖：一是指向srvnet_recv结构的指针（偏移0x120处），二是用于接收缓冲的MDL指针⁹。控制MDL指针可以让攻击者通过TCP栈造成任意写；控制结构指针可伪造对象并最终在连接断开时执行代码⁹。利用永恒之蓝实现的具体方式是：溢出后将MDL写为0xffdff000，并让后续SMB数据写入这一地址+0x80处¹⁰。在该内存处首先写入一个伪造的srvnet_recv结构，结构中的回调函数指针字段被设为0xffdff1f1（即紧跟的Shellcode起始处）¹¹。0xffdff000地址属于系统保留信息区且可执行¹⁰。最后，攻击者只需关闭SMB连接，触发Windows调用srvnet_recv结构中的回调函数（一般由SrvNetWskReceiveComplete触发），即跳转到攻击者控制的Shellcode并获得SYSTEM权限执行¹¹。官方补丁公告也指出：攻击者发送特制的SMBv1报文可导致远程代码执行¹²，与上述分析相符。

漏洞利用实现

永恒之蓝利用模块结合了精心构造的SMB报文和内存“喷洒”（heap spray）技巧。具体流程如下：首先，攻击者向目标发起一个带有特制FEA列表的SMB_COM_NT_TRANSACTION请求，FEA列表长度设为0x10000（包含0x10000字节FEA），这样TotalDataCount为0x103d0⁵。随后发送多次SMB_COM_TRANSACTION2_SECONDARY（保持相同的Tree/Process/User/Multiplex ID），使服务器将整个事务视为一个0x103d0字节长的请求⁵。在等待最后一个分包时，攻击者通过以下方式准备内存布局^{13 10}：

- 喷洒srvnet对象：发起大量新的SMB2连接（或TRANS2会话）在非分页池中分配相似的srvnet缓冲区。

- **会话建立漏洞利用**：利用 `SMB_COM_SESSION_SETUP_ANDX` 命令的一个已知BUG（使用错误的WordCount和Flags字段），精确申请一个大小为0x0C68的非分页池块。这样该块恰好位于先前分配的部分 `srvnet` 对象之后。
- **再次喷洒**：继续发起SMB连接喷洒更多的 `srvnet` 对象，使其中一个新的 `srvnet` 对象与前述空闲块相邻。
- **制造空洞**：断开之前的一个连接，释放其中的非分页池块，从而在两个喷洒的 `srvnet` 对象之间留下一个大约0x0C68大小的空洞。
- **触发溢出**：最后发送上一事务的最后一个 `SMB_COM_TRANSACTION2_SECONDARY` 分包，使得总长度达到0x103d0并触发越界写。溢出数据恰好填充到前一个步骤准备好的空洞，覆盖了第一个 `srvnet` 对象的MDL和指针^{13 9}。

形成上述内存布局后，溢出写入的Shellcode被定向到 `0xffdf000` 处¹⁰。在32位Windows 7/2008 R2环境中（无SMEP限制），执行以上步骤即可直接触发Shellcode执行并获得SYSTEM权限。在现代64位系统上（启用SMEP/DEP），利用通常需额外进行ROP链操作：公开资料显示，对Windows 8及以上的利用会“先触发漏洞两次，第一次将MDL指向目标页表条目并清零以取消NX位，第二次再像Win7一样触发，以实现代码执行”¹⁴。总之，永恒之蓝利用结合了SMB消息精心构造、内存喷洒与ROP/NX绕过等多重技术，最终在内核态获得SYSTEM级执行。

DoublePulsar 后门注入逻辑

EternalBlue利用成功后，常配合NSA泄露的DoublePulsar后门在内核中驻留shellcode，以便后续隐蔽持久控制。DoublePulsar后门劫持了SMB的事务表，在收到特定“`trans2 SESSION_SETUP`”格式报文时，按**ping/exec**模式处理载荷。具体来说：攻击者首先向目标发送一个带“ping”操作码的 `SMB_COM_TRANSACTION2 (SESSION_SETUP)` 请求，后门响应中会返回一个部分**XOR密钥**¹⁵。接着攻击者分块（每块4096字节）发送完整的恶意Shellcode数据，每个分块都封装在带“exec”操作码的 `trans2 SESSION_SETUP` 请求中。后门使用事先获取的XOR密钥对数据流进行简单加密，收到后在内核中为Shellcode分配可执行缓冲区，解密并复制代码，然后跳转执行¹⁶。这样，攻击者可以将任意（例如DLL装载）payload注入内核并运行，同时其内核钩子“隐藏”在 `SrvTransactionNotImplemented` 表中，**几乎不触发PatchGuard等防护报警**¹⁷。通过上述流程，DoublePulsar利用SMB会话便捷地注入并执行了自定义Shellcode，实现持续后门。

利用流程全景分析

从红队操作流程来看，利用永恒之蓝包括信息收集、确认漏洞、触发利用、提权以及部署后门等环节：

- **信息收集**：首先扫描目标网络的445端口（SMB）是否开放，例如使用Nmap或Metasploit扫描模块；确认目标运行的是未打补丁且启用SMBv1的Windows版本（Windows XP/7/2008 R2等）^{18 19}。旧版Windows默认允许匿名登录IPC\$，且SMBv1协议开启，因此满足利用条件^{18 4}。
- **漏洞触发**：使用专用EXP或Metasploit模块构造并发送上述定制的 `SMB_COM_NT_TRANSACT` 和分包（Secondary）请求^{5 13}。如果环境满足条件，目标将执行回溢行为并在内核中触发Shellcode。
- **权限提升**：一旦成功触发，攻击者便可在目标机器上取得 `NT AUTHORITY\SYSTEM` 权限的Shell或Meterpreter会话¹⁹。在这一过程中无需交互式登录；如MS17-010公告所示，这是一种“无需身份验证即可执行远程代码”的漏洞^{12 20}。
- **后门部署**：获得高权限后，红队通常会在内核中安装后门或注入额外payload。典型做法是利用上述DoublePulsar后门机制，通过SMB `SESSION_SETUP` 注入计算机蠕虫或自定义DLL^{15 21}。也可以利用我们控制的系统权限持续部署用户态后门（如新建管理员账户、植入服务、注册表启动项等）。

整个利用过程中，红队将结合协议指纹、漏洞探测和隐蔽手法，实现从发现到获shell再到后续持久化的完整链路^{19 16}。

利用条件与目标限制

EternalBlue对Windows版本有严格的适用范围：**影响系统**包括Windows XP、Vista、7、2008、2008 R2、2012、2012 R2（部分旧版Win10亦受影响）¹⁸。这些旧系统默认启用SMBv1并允许IPC\$匿名会话，使得攻击“在不需要任何凭证的情况下即可实施”¹⁸³。而Windows 8及以后版本默认禁止匿名访问任何共享（包括IPC\$），且现代系统中SMBv1协议已被弃用或默认禁用⁴。此外，Win8+/10引入了更严格的内核保护：启用了SMEP/DEP并随机化了内核基址（KASLR）。对抗这些防护需要额外步骤，例如利用SMB交易竞态泄漏内核内存以获取地址信息²²，或在内核中扫描IDT来定位ntoskrnl.exe基址²³，以及使用ROP链或NX取消等方式绕过执行保护¹⁴²²。因此，现代系统（更新补丁、SMBv1关闭或开启内核保护）下永恒之蓝的成功率和稳定性都大大降低，往往需要结合复杂的辅助漏洞或高级攻击工具才能实现。

红队视角的利用策略

从红队角度出发，永恒之蓝的隐蔽利用和后续持久性是重点考虑对象。首先，由于漏洞利用发生在内核层面且通过正常的SMB协议通道触发，很多安全监测（尤其用户态的EDR）难以直接检测到此过程。双脉冲后门通过修改SrvTransaction2DispatchTable挂钩内核函数，其钩子常驻于难以察觉的位置，“不会触发PatchGuard之类的防护”¹⁷，使得后门相对隐蔽。红队可进一步**减小留痕**：例如在利用过程中尽量避免使用可疑用户名/账户，不在目标机器上直接落地可执行文件，而是利用无文件后门（如注册表Run键、WMI事件订阅）实现持久化²⁴。如同实战经验所示，使用文件隐藏的注册表启动项或WMI Event订阅可比常规的自启动程序更为隐蔽，难以被检测²⁴。另外，利用成功后可创建另一个受信任账户或服务来维持访问，使用反向Shell或内存注入工具（如Cobalt Strike）以防止蓝队通过文件扫描发现。

最后，红队在攻击链后端应做好清理痕迹：尽量清除或更改日志（如SMB、系统安全日志）中暴露利用行为的条目，避免留下明显的溢出或提权特征；同时在植入后门时采用加密通信和协议伪装，降低行为检测的风险。总之，将永恒之蓝与DoublePulsar、后门注入及文件无害化持久化等技术结合，能够在内网渗透中实现“静默”提权和隐蔽持久控制¹⁷²⁴。

参考文献： 本报告所述技术细节及利用步骤主要参考了公开研究和分析资料⁶⁵¹³¹⁵²²¹⁸⁴等。所有引用均为公开内容以供参考。

¹ [MS-CIFS]: Message Syntax | Microsoft Learn

https://learn.microsoft.com/en-us/openspecs/windows_protocols/ms-cifs/089b6f3e-b91d-4659-83a7-3e50a1a5faf7

² Microsoft SMB Protocol and CIFS Protocol Overview - Win32 apps | Microsoft Learn

<https://learn.microsoft.com/en-us/windows/win32/fileio/microsoft-smb-protocol-and-cifs-protocol-overview>

³ ⁷ EternalBlue - Everything There Is To Know - Check Point Research

<https://research.checkpoint.com/2017/eternalblue-everything-know/>

⁴ ¹⁴ Rapid7 Vulnerability Database

https://www.rapid7.com/db/modules/exploit/windows/smb/ms17_010_eternalblue_win8/

⁵ ⁶ ⁸ ⁹ ¹⁰ ¹¹ ¹³ 奇安信威胁情报中心

<https://ti.qianxin.com/blog/articles/detailed-analysis-of-eternalblue/>

¹² Microsoft Security Bulletin MS17-010 - Critical | Microsoft Learn

<https://learn.microsoft.com/en-us/security-updates/securitybulletins/2017/ms17-010>

¹⁵ ¹⁶ ¹⁷ ²³ zerosum0x0: DoublePulsar Initial SMB Backdoor Ring 0 Shellcode Analysis

<https://zerosum0x0.blogspot.com/2017/04/doublepulsar-initial-smb-backdoor-ring.html>

18 19 20 21 24 永恒之蓝 (EternalBlue) 漏洞复现--详细教学-CSDN博客

https://blog.csdn.net/m0_57736664/article/details/149430463

22 BadRabbit MS17-010 Exploitation Part One: Leak and Control

<https://www.crowdstrike.com/en-us/blog/badrabbit-ms17-010-exploitation-part-one-leak-and-control/>